

บทที่ 9

Passport System

9.1 หลักการทำงาน

Passport เป็นบริการที่ช่วยให้ผู้ใช้สามารถสร้างชื่อและรหัสผ่านสำหรับลงชื่อเข้าใช้แบบครั้งเดียวสำหรับใช้กับทุกบริการและทุกไซต์ที่มีบริการของ Passport



รูปที่ 9-1 โครงสร้างพื้นฐาน Web service

9.2 การเก็บรวบรวมข้อมูลส่วนตัวโดย PASSPORT

9.2.1 ข้อมูลชนิดใดบ้างที่ Passport เก็บรวบรวม

เมื่อใดที่คุณลงทะเบียนขอใช้ Passport ก็จะปรากฏข้อความแจ้งให้กรอกข้อมูลส่วนตัวที่จะถูกเก็บไว้ใน "แฟ้มประวัติ" สำหรับ Passport ตามที่ได้อธิบายไว้ด้านล่างนี้ ปริมาณข้อมูลที่มีการขอร้องให้กรอกนั้นจะแตกต่างกันไปตามแต่ละไซต์ที่ทำการลงทะเบียนขอใช้บริการ แต่ส่วนใหญ่แล้วแฟ้มประวัติสำหรับ Passport จะประกอบไปด้วยข้อมูลดังต่อไปนี้คือ (1) ที่อยู่อีเมลล์ (2) ชื่อต้นและชื่อสกุล (3) ประเทศหรือภูมิภาค (4) รัฐหรือดินแดน (5) รหัส ZIP หรือรหัสไปรษณีย์ (6) ภาษา (7) โซนเวลา (8) เพศ (9) วันเกิด และ (10) อาชีพ

9.2.2 การกำหนดข้อมูลที่จะเก็บรวบรวมโดยไซต์ที่ทำการลงทะเบียน

คุณสามารถลงทะเบียนขอใช้ Passport จากบริการหรือไซต์ที่มีบริการของ Passport หรือจากเว็บไซต์ Passport ได้ ซึ่งไซต์ที่ทำการลงทะเบียนจะเป็นตัวกำหนดปริมาณข้อมูลที่ Passport จะเก็บรวบรวมไว้ขณะที่มีการลงทะเบียน

9.3 การบริหารจัดการข้อมูลส่วนตัวของคุณ

9.3.1 การเข้าไปใช้ข้อมูลส่วนตัวของคุณ

คุณสามารถเพิ่ม ปรับปรุง หรือทำการเปลี่ยนแปลงอื่น ๆ กับข้อมูลใน ของคุณ ได้ตลอดเวลา

9.3.2 การปิดบัญชี Passport ของคุณ

ผู้ให้บัญชี Passport จะเป็นผู้กำหนดขั้นตอนการปิดบัญชี Passport อันนั้นของคุณ ดังอธิบายไว้

9.3.3 ความปลอดภัยและแหล่งเก็บข้อมูลส่วนตัว

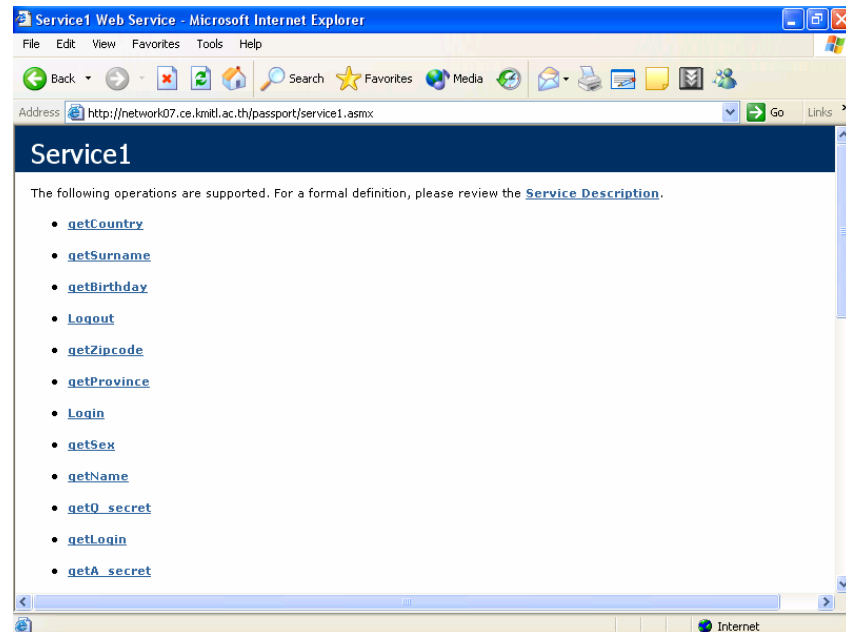
เมื่อคุณแสดงความจำนงให้มีการส่งข้อมูลสำหรับ Passport ของคุณ ไปยังไซต์ที่มีบริการของ Passport นั้น Passport จะใช้เทคโนโลยีด้านการรักษาความปลอดภัยมาตรฐานอุตสาหกรรมในการเข้ารหัสลับข้อมูลเพื่อส่งผ่านทางอินเทอร์เน็ตอย่างปลอดภัย

9.3.4 การใช้งานคุกกี้

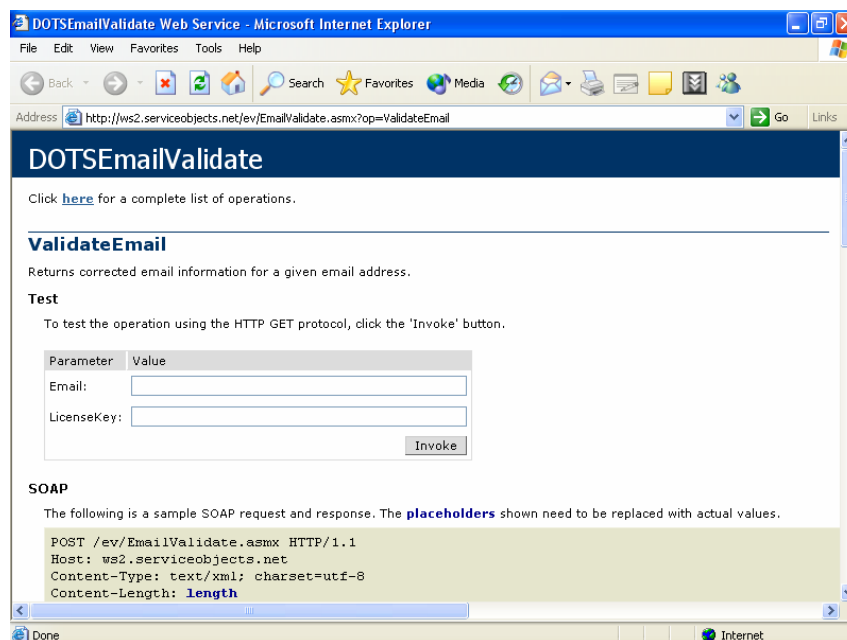
คุกกี้ คือแฟ้มข้อความขนาดเล็กมากที่เว็บไซต์บันทึกลงบนฮาร์ดดิสก์ของคอมพิวเตอร์เพื่อเก็บข้อมูลที่คุณกรอกเกี่ยวกับตัวเอง หรือเพื่อเก็บข้อมูลสิ่งที่คุณชอบของคุณ Passport จะใช้คุกกี้ทุกครั้งที่คุณลงชื่อเข้าใช้ไซต์ที่มีบริการของ Passport โดยจะเก็บตัวบ่งชี้เอกลักษณ์ของคุณ เวลาที่คุณเคยลงชื่อเข้าใช้ และข้อมูลใดก็ตามในแฟ้มประวัติสำหรับ Passport ที่คุณได้เลือกไว้เพื่อแบ่งให้ใช้ร่วมกับไซต์ที่มีบริการดังกล่าวจากในคุกกี้ที่เข้ารหัสลับอย่างรัดกุมบนฮาร์ดดิสก์

9.4 ส่วนตัวระบบ

สามารถใช้บริการของ web service ตามรูป โดยออกแบบให้สามารถเรียกใช้ service เพิ่มประวัติของลูกค้าได้ไม่ว่าจะเป็น วันเดือน ปีเกิด ที่อยู่ สถานะ อื่นๆ ที่ได้กล่าวมาแล้ว



รูปที่ 9-2 แสดง service ต่างๆใน รูปแบบ asmx ของ ระบบ passport



รูปที่ 9-3 แสดง service ตรวจสอบ e-mail ใน รูปแบบ asmx

9.4.1 ความปลอดภัย

เราได้เพิ่มส่วนการทำงานจากการทำงานปกติคือ

1. การทำ input & output validation
2. การใช้ HTML forms
3. การใช้ Cookies
4. การใช้ HTTP REFERER Header
5. การใช้ POST & GET method
6. มีกระบวนการในการทำ logout(logout machanism)
7. Error Handling

การทำ input & output validation

1. ในการทำงานของเว็บแอปพลิเคชัน จะมีการรับข้อมูลบางอย่างจาก user เพื่อใช้ในการทำงาน และทำการส่งผลลัพธ์ไปให้ user ซึ่งอินพุตจากยูสเซอร์ เป็นสาเหตุหลัก ที่ทำให้ระบบเกิดความไม่ปลอดภัย โดยผู้เขียนระบบต้องพึงระลึกถึงว่าไม่ควรเชื่อถือข้อมูลใดๆที่ส่งมาจากฝั่ง ไคลเอนต์
2. สำหรับ Client Side Script เช่น JavaScript ,VBScript อื่นๆ สามารถเปลี่ยนแปลงได้จึงไม่ควรเชื่อผลลัพธ์มากนัก
3. ทำ Sanity Checking โดยการตรวจสอบ input ทุกอย่างที่เข้ามาในระบบ เพื่อตรวจสอบว่าข้อมูลที่เรากำลังต้องการมีอะไรบ้าง เช่นถ้า input ที่ต้องการ เป็น yes หรือ no เท่านั้นจะต้องทำการ drop ข้อมูลอื่นๆที่รับเข้ามาทิ้งไป
4. ควรมีการตรวจสอบอักขระพิเศษต่างๆด้วย เพื่ออักขระพิเศษต่างมักเป็นต้นกำเนิดของปัญหาการใช้ฟังก์ชัน หรือ system call ที่ผิดปกติ
5. ถ้าเว็บแอปพลิเคชันไม่จำเป็นต้องใช้งานตัวอักษร HTML ต่างๆ ก็ควรทำการกรองตัวอักษร HTML ก่อนและเปลี่ยนรูปแบบตัวอักษรให้รูปอื่น เช่น > เปลี่ยนเป็น >
6. การดึงข้อมูลจากฐานข้อมูลแล้วแสดงผลให้ กับยูสเซอร์ควรมีการกรองข้อมูล และเปลี่ยนแปลงค่าตัวอักษรที่อยู่ในข้อมูล HTML ก่อน เพื่อป้องกันการส่งคำสั่งมาทำงานที่เซิร์ฟเวอร์

9.4.2 การใช้ html forms

การใช้ hidden form element โดยจะมอง hidden เป็นเหมือนกับข้อมูลที่ได้รับมาจากUser แต่ไม่ควรใช้กับข้อมูลที่มีความสำคัญมาก

9.4.3 การใช้ Cookies

Cookies เป็นเนื้อที่ในการเก็บข้อมูลในการทำงานบางส่วนไว้ที่ ไคลเอนต์ โดยมี สองประเภท คือ

1. persistent : เป็น Cookie ที่ไม่มีการลบข้อมูลออกแม้ว่าจะปิดแอปพลิเคชันไปแล้วก็ตาม
2. non-persistent : เป็น Cookie ที่ลบข้อมูลออกจาก ไคลเอนต์เมื่อหมดเวลา หรือเมื่อปิดแอปพลิเคชันไปแล้ว

9.4.4 การใช้ HTTP REFERER Header

การป้องกัน script attack อีกทางหนึ่งที่สามารถป้องกัน script attack ได้บ้าง แต่ป้องกันได้ไม่หมด

9.4.5 การใช้ POST & GET method

ไม่ควรใช้ method GET ในการส่งข้อมูลที่มีความสำคัญ ในกรณี เว็บแอปพลิเคชันควรใช้ POST เท่านั้น และควรตั้งค่าให้ เซิร์ฟเวอร์ตอบสนองเฉพาะ POST เท่านั้น

มีกระบวนการในการทำ logout (logout mechanism)

การเพิ่มกระบวนการในการ Logout ในการทำงานต่างๆ ในเว็บแอปพลิเคชัน นั้น มีประโยชน์ในการ

1. ลบ Cookies หรือทำให้ Cookies ที่ฝั่งไคลเอนต์ไม่สามารถทำงานได้
2. จัดการกับ session ทางฝั่งเซิร์ฟเวอร์เพื่อป้องกันการขโมย session ในกรณี Cookie ที่ไคลเอนต์ไม่หมดอายุ

9.5 Error Handling Mechanism

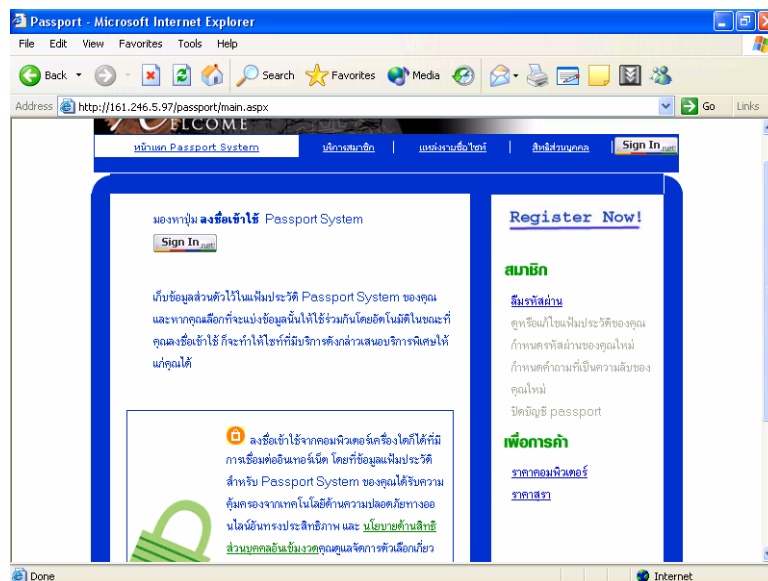
การทำ Error Handling ที่มีการแจ้ง Error Description นั้น เป็นประโยชน์ในการแก้ปัญหาที่มัก ไม่ควรส่ง Error Description ต่างๆ ไปให้ user เนื่องจากจะทำให้ผู้บุกรุกรู้รายละเอียดได้

9.6 การติดตั้ง

ไม่ต้องทำการติดตั้งเพราะการทำงานอยู่ในรูปของ Web สามารถนำไฟล์ไปเก็บไว้ที่ Web Server แล้วสร้างตารางฐานข้อมูลที่มีชื่อตารางและชื่อคอลัมน์เหมือนกับที่แสดงไว้ในส่วนของการออกแบบก็สามารถใช้งานได้เลย

9.7 การใช้งาน

เมื่อเข้ามาที่ web passport ดังรูป



รูปที่ 9-4 แสดงหน้า Web Passport

ประกอบด้วยเมนูใหญ่

1. หน้าแรก passport system
2. บริการสมาชิก
3. สิทธิส่วนบุคคล

9.7.1 หน้าแรก passport system

สำหรับผู้ที่ยังไม่ได้ทำการสมัครเป็นสมาชิกของ Passport จะต้องทำการสมัครสมาชิกก่อนโดยคลิกที่ Register Now! จะทำการเข้าสู่ หน้าการลงทะเบียนผู้ใช้ใหม่

Step 1: กรอกที่อยู่อีเมลและรหัสผ่านของคุณ เพื่อทำการลงทะเบียนเป็นสมาชิก ดังรูปที่ 9-5 ซึ่งในขั้นตอนนี้จะมีการเรียกใช้บริการจากภายนอก เพื่อทำการตรวจสอบว่า มีอยู่จริงหรือไม่ ตามรูปที่ 9-3(ข) ซึ่ง ถ้ามีจะสามารถทำงานต่อไปได้ เลือกทำต่อไป ถ้าไม่ได้กรอกข้อมูลหรือป้อนรหัสไม่เหมือนกันจะทำการแจ้งเตือนให้กรอกข้อมูลให้ครบ

รูปที่ 9-5 แสดงหน้าให้กรอกที่อยู่อีเมลและรหัสผ่านของคุณ เพื่อทำการลงทะเบียนเป็นสมาชิก

Step 2: กรอกข้อมูลส่วนตัวของคุณ เพื่อทำการลงทะเบียนเป็นสมาชิก ดังรูป

รูปที่ 9-6 แสดงหน้ากรอกข้อมูลส่วนตัว เพื่อทำการลงทะเบียนเป็นสมาชิก

Step 3: กรอกคำถามของคุณ เพื่อใช้เมื่อลืมรหัสผ่าน ดังรูป

รูปที่ 9-7 แสดงหน้ากรอกคำถาม เพื่อใช้เมื่อลืมรหัสผ่าน

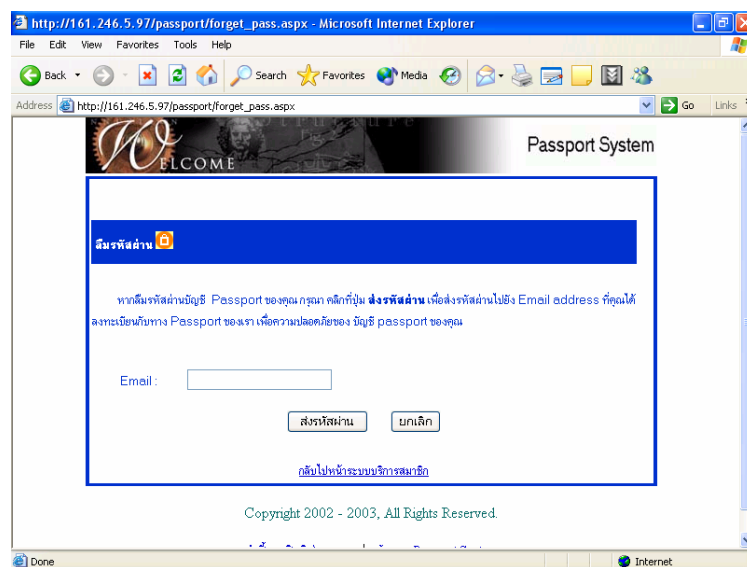
Step 4: เสร็จสิ้นการสมัคร

รูปที่ 9-8 แสดงหน้าเสร็จสิ้นการสมัคร

และสามารถทำการแก้ไขข้อมูลดังต่อไปนี้

1. เข้าไปแก้ไขประวัติได้
2. กำหนดรหัสผ่านใหม่ จะต้องทำการใส่ password เก่า ก่อนแล้วใส่ password ใหม่
3. กำหนดคำถามที่เป็นความลับ
4. สามารถทำการยกเลิกการใช้งาน passport ได้

สำหรับสมาชิกที่ ลืม password ลืมรหัสผ่านก็จะหน้า ลืมรหัสผ่าน จะให้ทำการ ใส่ข้อมูล e-mail แล้วคลิก ส่งรหัสผ่าน ระบบจะทำการตรวจสอบ e-mail แล้วทำการส่ง password นั้น ไปที่ e-mail นั้น

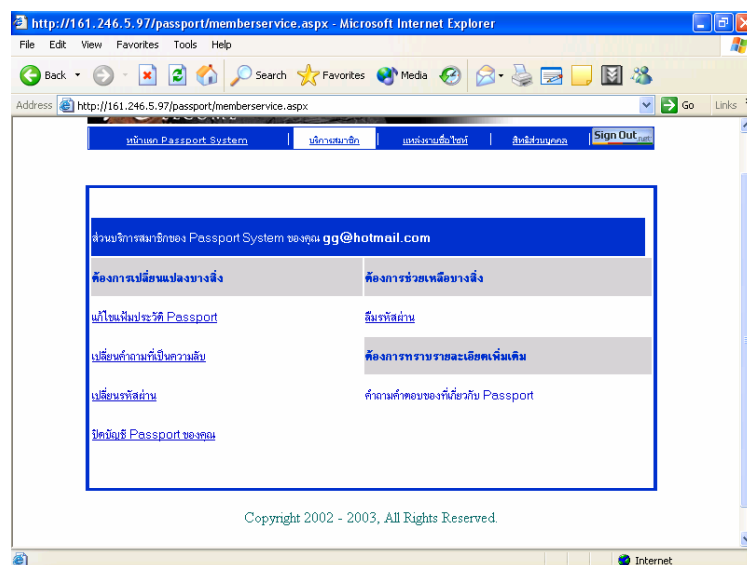


รูปที่ 9-11 แสดงหน้าสำหรับกรอก e-mail เมื่อ ลืมรหัสผ่าน

9.7.2 บริการสมาชิก

เป็นหน้าที่ให้บริการสำหรับสมาชิกโดยต้องทำการ login ก่อนถึงจะเข้าสู่การทำงานหน้านั้นได้ ดัง

รูป



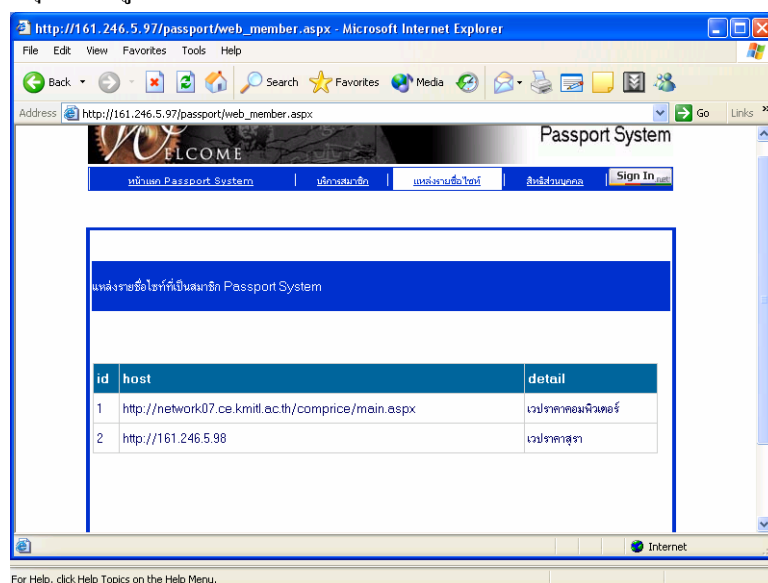
รูปที่ 9-12 เป็นหน้าที่ให้บริการสำหรับสมาชิก

ประกอบด้วย

- 2.1 เข้าไปแก้ไขประวัติได้
- 2.2 กำหนดรหัสผ่านใหม่
- 2.3 กำหนดคำถามที่เป็นความลับ
- 2.4 สามารถทำการยกเลิกการใช้งาน passport ได้

9.7.3 แหล่งรวม เว็บไซต์

ประกอบด้วย web ที่เป็นสมาชิกของ passport การเข้าใช้งานของต้องคลิก ปุ่มเพื่อทำการ Sign In เข้าสู่ระบบ ป้อน e-mail กับ password เว็บนั้นก็สามารถใช้ข้อมูลของสมาชิกที่สมัครไว้ที่ passport ตามเงื่อนไขสิทธิส่วนบุคคลดังรูป



รูปที่ 9-13 web ที่เป็นสมาชิกของ passport

9.7.4 สิทธิส่วนบุคคล

เป็นรายละเอียดสิทธิส่วนบุคคลของ passport ข้อกำหนดการใช้งานต่างๆ เมื่อต้องการออกจากระบบ passport ต้องทำการกด  ก็จะออกจากระบบ passport